

API Security & Zero-Trust Authentication Standards

Security Compliance Document | SEC-STD-2026

1. Authentication Architecture

All API communication must be encrypted in-transit via TLS 1.3. User identity verification relies on JWT (JSON Web Tokens) signed using asymmetric RS256 cryptography:

- * Access Token Lifespan: 15 minutes (short-lived, non-renewable).
- * Refresh Token Lifespan: 7 days, stored in HttpOnly, SameSite=Strict, Secure cookies.
- * Key Rotation: Automated key rotation every 30 days via JWKS endpoints.

2. Input Sanitization & Threat Mitigation

* Raw File Uploads: Inspected for magic bytes to prevent MIME-spoofing attacks (e.g. executable disguised as PNG).

* Path Traversal Defense: All filenames sanitized using UUID deterministic hashing; direct client path inputs rejected.

* SQL Injection Protection: All database interactions strictly execute via parameterized SQLAlchemy ORM queries.

3. CORS & CSRF Directives

- * Allowed Origins: Explicitly whitelisted frontend origin (e.g., http://localhost:5173). Wildcards (*) prohibited.
- * Allowed Methods: GET, POST, PUT, DELETE, OPTIONS.
- * Allowed Headers: Authorization, Content-Type, X-Request-ID.